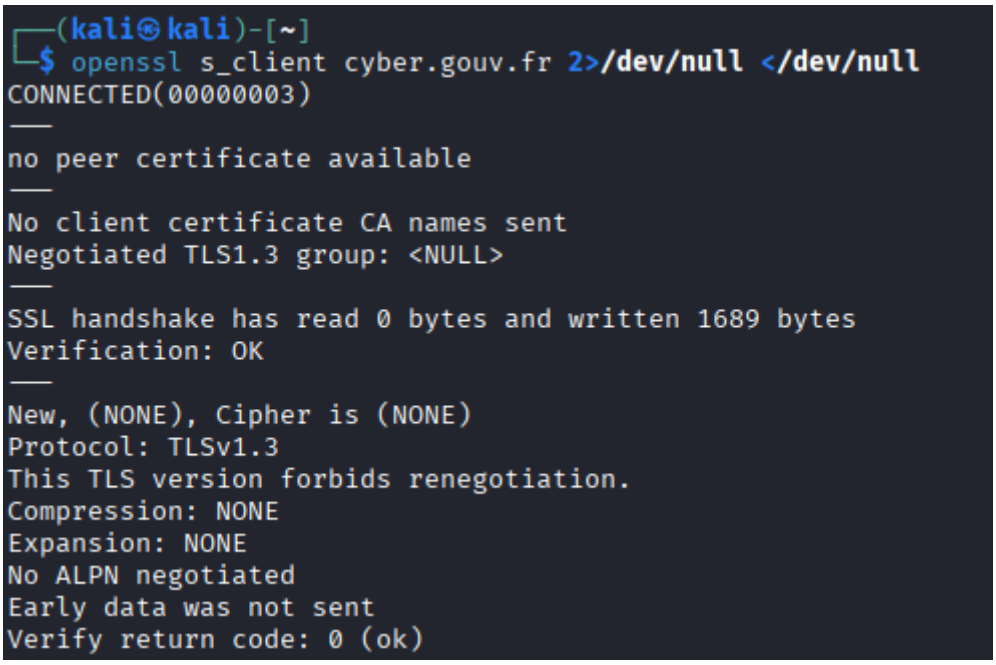
TP Applications de la Cryptographie

Etude des certificats, de leurs caractéristiques

1. **Quel protocole sécurise cette connexion lors de la consultation d'un navigateur ?**

`openssl s_client cyber.gouv.fr 2>/dev/null </dev/null`



Le protocole qui sécurise cette connexion est TLSv1.3

J'ai aussi lancé cette commande pour récupérer plus d'informations :

`openssl s_client -connect cyber.gouv.fr:443 -showcerts </dev/null 2>/dev/null | openssl x509 -outform PEM > cyber.gouv.fr.pem`

Explications :

- `s_client -connect`: établit une connexion TLS/SSL vers le site.
- `-showcerts`: affiche toute la chaîne de certificats (serveur + intermédiaires + racine).
- `openssl x509 -outform PEM`: extrait le certificat en format PEM.

`cat cyber.gouv.fr.pem`

```
┌──(kali㉿kali)-[~]
└─$ cat cyber.gouv.fr.pem
-----BEGIN CERTIFICATE-----
MIIILjCCBhagAwIBAgIQDD+lXMFfG9wSDlGw08XotDANBgkqhkiG9w0BAQsFADB2
MQswCQYDVQQGEwJGUjERMA8GA1UECgwIQ2VydGlnbmExHTAbBgNVBGEMFE5UUkZS
LTQ4MTQ2MzA4MTAwMDM2MTUwMwYDVQQDDCxDZXJ0aWduYSBTZXJ2ZXIgQXV0aGVu
dGljYXRpb24gT1ZDUCBFVSBDQSBHMTAeFw0yNTEwMDcwMDAwMDBaFw0yNjAxMDQy
MzU5NTlaMFwxCzAJBgNVBAYTAkZSMREwDwYDVQQHDAhQQVJJUyBTUDEOMAwGA1UE
CgwFU0dEU04xFDASBgNVBAMMC3NzaS5nb3V2LmZyMRQwEgYDVQQFEwtTMzYwNDUw
Mjg5NDCCAaIwDQYJKoZIhvcNAQEBBQADggGPADCCAYoCggGBAJSZy6hOGeHTGzjb
w5OmEUsowiUxA2UDGScM1ucAeb2CItG15RuUuVn56UTzNLr0mewmELzZXMcUMFdQ
sUy347yhFgr/XCGKHnPZi+0Fea0LMslv+D4jn2xvxW6IcKbbtS2xzhNiGDseNS7L
Hbf8jDqE7IvcpPDGxDhNbHIpntx3SusuvhLGQl44M4HAc/LIJF2TjagvdITpXDlJ
Y9SeAUR2Oxs6WdZW3qCQ3aBPzo3EPBg0nrTbMITU/zfruKJRjd4Fso5IIKPw71m5
OzGSvFdPEsnzAE+YMyWJMhaE848vCs2ansy40FbTY3Ee6a+D244DEeXfwkHn6Fbg
mGq6/gtcAZ9oc+Qa/9vA1++ke04RPRIsrae+iE3SCesb9bQ6g+EL0t+k6fPu8R/r
UD9XjhahkFdFoUKfYksmb81rkhT/KAaSqsA6BegVkO1mOIGRO1QNN7LAEe9UT2Rw
rkkE2Xlya736giJFJyqzx+Ack2PpgJ1Hwz2UWIuvTIXDqaP0HQIDAQABo4IDUDCC
A0wwXwYIKwYBBQUHAQEEUzBRME8GCCsGAQUFBzAChkNodHRwOi8vY2VydC5jZXJ0
aWduYS5jb20vQ2VydGlnbmFTZXJ2ZXJBdXRoZW50aWNhdGlvbk9WQ1BFVUNBRzEu
Y2VyMB8GA1UdIwQYMBaAFKBy5kbEMFzkrcIcwtViOJiBWlSmMAwGA1UdEwEB/wQC
MAAwUwYDVR0gBEwwSjAIBgYEAI96AQcwNAYLKoF6AYExARcBAQEwJTAjBggrBgEF
BQcCARYXaHR0cDovL2Nwcy5jZXJ0aWduYS5jb20wCAYGZ4EMAQICMFMGA1UdHwRM
MEowSKBGoESGQmh0dHA6Ly9jcmwuY2VydGlnbmEuY29tL0NlcnRpZ25hU2VydmVy
QXV0aGVudGljYXRpb25PVkNQRVVDQUcxLmNybDATBgNVHSUEDDAKBggrBgEFBQcD
ATAOBgNVHQ8BAf8EBAMCBaAwSQYDVR0RBEIwQIINY3liZXIuZ291di5mcoILc3Np
LmdvdXYuZnKCD3d3dy5zc2kuZ291di5mcoIRd3d3LmN5YmVyLmdvdXYuZnIwHQYD
VR0OBBYEFJ9f21zVTrcowTYHg8LmWPac6C/ZMIIBfwYKKwYBBAHWeQIEAgSCAW8E
ggFrAWkAdQB0251Y99R+nf14ehYqmRwYz2mNp8cpkYyaGLBFDbpEvAAAAZm9tV8F
AAAEAwBGMEQCIHt1OI1mJFyAjgjhaPXn7qI6WJrSuEh28Nk8t6zFSOOiAiArn/et
9CWFPLmoFkmAWengSB0YPVRZ6aDsRJApT05GnAB3AA5XlLzzrqk+MxssmQez95Df
m8I9cTIl3SGpJaxhxU4hAAABmb21X3IAAAQDAEgwRgIhAOi0H/YLAf4Ey1oSSq93
MsPBGJNa1ID5ZRxYYKmK10e8AiEAtKA9T4tIENDqQrfHw8kTmOxUnFvsFU7fchF9
ERhSL4YAdwAZhtTHKKpv/roDb3gqTQGRqs4tcjEPrs5dcEEtJUzH1AAAAZm9tWIZ
AAAEAwBIMEYCIQD0BMe5wcWHVKJOY8+nCG8deFZDAofWlEFElQ8cIp4X4gIhAJCk
+Kg9RyVlBStH8WeoaLnhtF9AmV+sOVN53nrRPNOZMA0GCSqGSIb3DQEBCwUAA4IC
AQARHtOIPD8dlB4s+j+bRNlZLzfdQqVcoU1F8QIpPzpvcnpN7N9yCOZU+Q6Auuyr
2FzjtjYblCt3qpHOlV4qDJMk2LNBnFweWdPej5DHxJgfFjRH77fhqhzVH7Ro21oS
+joYkdMlAVcNyZ/KQpKFilm2+OdGB/JaVCpujFlFtIvVuPl91uMfvvlzRI7v1D4N
KaAxJeqGoNRpVD6QvCiLUJzX/IYGx+maocyX19NfvYVmoLhAceHHVDA3U3csrz35
mPnVt4lSwbsMCqyDU6PKr8xmicqt0kxfi3f0B9hMlg9lJFtKJOQS/UUlhKdhtBz/
EVdbUdhB6xyNgfYBUFBJhSlP3frohGWKEJwl7iZyL56Es22E5pm6tC4TjPYPwuM7
MKYbjbYFbzgXUk8YS7cI6Oehlck4kwmURgTx7UWSOaz1dHTz4SzaIS68ozVzl3U2
aIyRzcX1iFUoqhimRKnqwauhaySpsJE3rn6eBYiyS0lhXDtcNkBNFZVeOGg7BUOQ
3bb8wnIcUDhsWF9mI/JvMeld+riaZz1YG8HVaqJVigzYkJOxZQmFx3M2Z8YCmST5
cAvwzCV2Xp1eKQfssfKpvYOec7Bgx1kGNgfIYsUhwHI7vMhwrGlh6zCNsUP9g8wn
bhA227Q27S7g+WGAzys21E/AwhzRDa3ti0EPRmcH4q0NpA==
-----END CERTIFICATE-----
```

2. **Quelle est la longueur de la chaine de certification ?**

Lancez cette commande pour voir plus d'informations sur le fichier `cyber.gouv.fr.pem`

```
openssl x509 -in cyber.gouv.fr.pem -text -noout
```

La longueur exacte de la chaîne de certification du site cyber.gouv.fr est de 3 certificats.

- Certificat du serveur : cyber.gouv.fr (ou ssi.gouv.fr).
- Autorité subordonnée (intermédiaire) : Certigna Server Authentication OVCP EU CA G1.
- Autorité racine : Certigna Root CA.

3. Quel est le nom de l'autorité de certification racine ?

Tu peux afficher les 3 certificats avec :

```
openssl s_client -connect ssi.gouv.fr:443 -showcerts
```

```
┌──(kali㉿kali)-[~]
└─$ openssl s_client -connect ssi.gouv.fr:443 -showcerts
Connecting to 185.231.164.136
CONNECTED(00000003)
depth=2 C=FR, O=Dhimyotis, CN=Certigna
verify return:1
depth=1 C=FR, O=Certigna, organizationIdentifier=NTRFR-48146308100036, CN=Certigna Server Authentication OVCP EU CA G1
verify return:1
depth=0 C=FR, L=PARIS SP, O=SGDSN, CN=ssi.gouv.fr, serialNumber=S3604502894
verify return:1
---
Certificate chain
 0 s:C=FR, L=PARIS SP, O=SGDSN, CN=ssi.gouv.fr, serialNumber=S3604502894
   i:C=FR, O=Certigna, organizationIdentifier=NTRFR-48146308100036, CN=Certigna Server Authentication OVCP EU CA G1
   a:PKEY: RSA, 3072 (bit); sigalg: sha256WithRSAEncryption
   v:NotBefore: Oct  7 00:00:00 2025 GMT; NotAfter: Jan  4 23:59:59 2026 GMT
```

L'autorité de certification racine est **`Certigna`**

4. Quel est le nom de l'autorité de certification subordonnée ?

L'autorité de certification subordonnée est **`Certigna Server Authentication OVCP EU CA G1`**

```
1 s:C=FR, O=Certigna, organizationIdentifier=NTRFR-48146308100036, CN=Certigna Server Authentication OVCP EU CA G1
  i:C=FR, O=Dhimyotis, CN=Certigna
  a:PKEY: RSA, 4096 (bit); sigalg: sha384WithRSAEncryption
  v:NotBefore: Feb 28 09:49:04 2025 GMT; NotAfter: Jun 28 09:49:03 2027 GMT
```

5. Quelle est la taille de la clé publique du site cyber.gouv.fr.pem ?

Le certificat du site cyber.gouv.fr.pem possède une clé publique RSA d'une taille de **`3072 bits`**, ce qui correspond à une clé de niveau de sécurité élevé, conforme aux politiques OVCP européennes.

```
Subject Public Key Info:
    Public Key Algorithm: rsaEncryption
        Public-Key: (3072 bit)
        Modulus:
            00:94:99:cb:a8:4e:19:e1:d3:1b:38:db:c3:93:a6:
            11:4b:28:c2:25:31:03:65:03:19:27:0c:d6:e7:00:
            79:bd:82:22:d1:b5:e5:1b:94:b9:59:f9:e9:44:f3:
            34:ba:f4:99:ec:26:10:bc:d9:5c:c7:14:30:57:50:
            b1:4c:b7:e3:bc:a1:16:0a:ff:5c:21:8a:1e:73:d9:
            8b:ed:05:79:ad:0b:32:c9:6f:f8:3e:23:9f:6c:6f:
            c5:6e:88:70:a6:db:b5:2d:b1:ce:13:62:18:3b:1e:
            35:2e:cb:1d:b7:fc:8c:3a:84:ec:8b:dc:a4:f0:c6:
            c4:38:4d:6c:72:29:9e:dc:77:4a:eb:2e:be:12:c6:
            42:5e:38:33:81:c0:73:f2:c8:24:5d:93:8d:a8:2f:
            74:84:e9:5c:39:49:63:d4:9e:01:44:76:3b:1b:3a:
            59:d6:56:de:a0:90:dd:a0:4f:ce:8d:c4:3c:18:34:
            9e:b4:db:30:84:d4:ff:37:eb:b8:a2:51:8d:de:05:
            b2:8e:48:20:a3:f0:ef:59:b9:3b:31:92:bc:57:4f:
            12:c9:f3:00:4f:98:33:25:89:32:16:84:f3:8f:2f:
            0a:cd:9a:9e:cc:b8:d0:56:d3:63:71:1e:e9:af:83:
            db:8e:03:11:e5:df:c2:41:e7:e8:56:e0:98:6a:ba:
            fe:0b:5c:01:9f:68:73:e4:1a:ff:db:c0:d7:ef:a4:
            7b:4e:11:3d:12:2c:ad:a7:be:88:4d:d2:09:eb:1b:
            f5:b4:3a:83:e1:0b:d2:df:a4:e9:f3:ee:f1:1f:eb:
            50:3f:57:8e:16:a1:90:57:45:a1:42:9f:62:4b:26:
            6f:cd:6b:92:14:ff:28:06:92:aa:c0:3a:05:e8:15:
            90:ed:66:38:81:91:3b:54:0d:37:b2:c0:11:ef:54:
            4f:64:70:ae:49:04:d9:79:72:6b:bd:fa:82:22:45:
            27:2a:b3:c7:e0:1c:93:63:e9:80:9d:47:c3:3d:94:
            58:8b:af:4c:85:c3:a9:a3:f4:1d
```

Plus en détail

Lancez cette commande pour bien afficher le certificat :

`openssl x509 -in cyber.gouv.fr.pem -text -noout`

6. **Observez le sujet du certificat. De quel de type de certificat s'agit-il ?**

```
Subject: C=FR, L=PARIS SP, O=SGDSN, CN=ssi.gouv.fr, serialNumber=S3604502894
```

A la ligne "Subject" → **`CN=ssi.gouv.fr`**

C'est un certificat de serveur web (TLS/SSL)

7. **Ce certificat peut-il être utilisé pour signer d'autre certificat ? Argumenter la réponse**

Vérifier le champ :

```
X509v3 extensions:
    Authority Information Access:
        CA Issuers - URI:http://cert.certigna.com/CertignaServerAuthenticationOVCPEUCAG1.cer
    X509v3 Authority Key Identifier:
        A0:72:E6:46:C4:30:5C:E4:AD:C2:1C:C2:D5:62:38:98:81:5A:54:A6
    X509v3 Basic Constraints: critical
        CA:FALSE
```

Non, car **CA:FALSE** signifie qu'il ne peut pas signer d'autres certificats. Si l'option était "**TRUE**", il aurait pu signer d'autres certificats

8. **Ce certificat peut-il être utilisé pour signer du courrier électronique ? Argumenter la réponse**

```
X509v3 Extended Key Usage:
    TLS Web Server Authentication
X509v3 Key Usage: critical
    Digital Signature, Key Encipherment
```

Non, car il ne contient pas d'usage S/MIME (emailProtection).

9. **A quel(s) endroit(s) trouve-t-on la CRL de l'autorité de certification ayant émis ce certificat ?**

```
X509v3 CRL Distribution Points:
    Full Name:
      URI:http://crl.certigna.com/CertignaServerAuthenticationOVCPEUCAG1.crl
```

La CRL (Certificate Revocation List) est disponible à cette URL : `http://crl.certigna.com/CertignaServerAuthenticationOVCPEUCAG1.crl`

10. **Observer le numéro de série. En quel format est-il ? Le convertir en décimal et émettre une observation à ce sujet.**

```
┌──(kali㉿kali)-[~]
└─$ openssl x509 -in cyber.gouv.fr.pem -text -noout
Certificate:
    Data:
        Version: 3 (0x2)
        Serial Number:
            0c:3f:a5:5c:c1:5f:1b:dc:12:0e:51:b0:d3:c5:e8:b4
```

C'est en hexadécimal. Pour convertir :

`echo "ibase=16; 0C3FA55CC15F1BDC120E51B0D3C5E8B4" | bc`

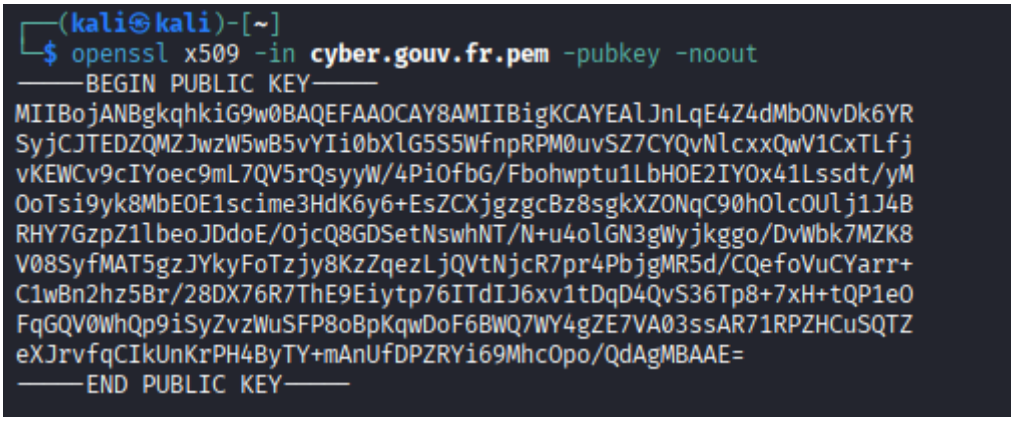
```
┌──(kali㉿kali)-[~]
└─$ echo "ibase=16; 0C3FA55CC15F1BDC120E51B0D3C5E8B4" | bc
16281204597927824865244904788878289076
```

Si vous avez le résultat "`Command 'bc' not found`". Installez avec :

`sudo apt install bc -y`

11. **Affichez la clé publique du certificat.**

```
openssl x509 -in cyber.gouv.fr.pem -pubkey -noout
```



12. Affichez la clé privée du certificat.

Impossible de l'afficher : seule l'autorité (propriétaire) la possède.

13. Combien de temps est-elle valide ?

```
wget
http://crl.certigna.com/CertignaServerAuthenticationOVCPEUCAG1.crl -O certigna.crl
```

```
openssl crl -in certigna.crl -inform DER -text -noout | head -n50
```

```
┌──(kali㉿kali)-[~]
└─$ openssl crl -in certigna.crl -inform DER -text -noout | head -n50
Certificate Revocation List (CRL):
        Version 2 (0x1)
        Signature Algorithm: sha256WithRSAEncryption
        Issuer: C=FR, O=Certigna, organizationIdentifier=NTRFR-48146308100036, CN=Certigna Server Authentication OVCP EU CA G1
        Last Update: Oct 23 23:51:54 2025 GMT
        Next Update: Oct 29 23:51:53 2025 GMT
        CRL extensions:
            2.5.29.60:
                ..20250228094904Z
            X509v3 Authority Key Identifier:
                A0:72:E6:46:C4:30:5C:E4:AD:C2:1C:C2:D5:62:38:98:81:5A:54:A6
            X509v3 CRL Number:
                499
Revoked Certificates:
    Serial Number: 1B0FA620FAB7C5A83C079615F5B840D2
        Revocation Date: Sep  3 08:53:17 2025 GMT
        CRL entry extensions:
            X509v3 CRL Reason Code:
                Superseded
    Serial Number: 1F44612A2EE23CA80CECBBB185975388
        Revocation Date: Aug 26 13:26:43 2025 GMT
        CRL entry extensions:
            X509v3 CRL Reason Code:
                Superseded
    Serial Number: 79A121816D8C794A7F6E9904321631C0
        Revocation Date: Sep  8 07:20:22 2025 GMT
        CRL entry extensions:
            X509v3 CRL Reason Code:
                Superseded
    Serial Number: AD79A8CD4598015E1832744C0157DA
        Revocation Date: Aug 27 14:20:29 2025 GMT
        CRL entry extensions:
            X509v3 CRL Reason Code:
                Superseded
    Serial Number: F8CE1D2030B5C86BBC4AB377A7332ACC
        Revocation Date: Jul 29 14:34:54 2025 GMT
    Serial Number: C90D3043F958C56B7496889348FDCCB2
        Revocation Date: Oct  7 07:20:51 2025 GMT
        CRL entry extensions:
            X509v3 CRL Reason Code:
                Superseded
    Serial Number: D53E41E1CFFA1C74BD57E6977E09D5CD
        Revocation Date: Sep  8 14:20:23 2025 GMT
        CRL entry extensions:
            X509v3 CRL Reason Code:
                Superseded
    Serial Number: DA7A826D058D569A3FF7CA0BC2404775
        Revocation Date: Aug 29 07:20:36 2025 GMT
        CRL entry extensions:
            X509v3 CRL Reason Code:
```

14. Les raisons de révocation des 1ers certificats révoqués apparaissent-elles ?

```
Revoked Certificates:
    Serial Number: 1B0FA620FAB7C5A83C079615F5B840D2
        Revocation Date: Sep  3 08:53:17 2025 GMT
        CRL entry extensions:
            X509v3 CRL Reason Code:
                Superseded
```

Oui. "**Superseded**" signifie que le certificat a été remplacé par un autre (`revoked`)

15. Comment être rapidement sûr que cette CRL est bien la bonne (émise par la bonne autorité de certification) ?
Argumenter la réponse

```
┌──(kali㉿kali)-[~]
└─$ openssl crl -in certigna.crl -inform DER -text -noout | head -n50
Certificate Revocation List (CRL):
        Version 2 (0x1)
        Signature Algorithm: sha256WithRSAEncryption
        Issuer: C=FR, O=Certigna, organizationIdentifier=NTRFR-48146308100036, CN=Certigna Server Authentication OVCP EU CA G1
```

Pour cela, il faut regarder l'issuer de la CRL pour vérifier qu'il est le même que celui de notre certificat cyber.gouv.fr.pem.

On peut aussi vérifier la signature numérique de la CRL avec la clé publique de cette autorité.

16. **Vérifiez manuellement si le numéro de série du certificat du site cyber.gouv.fr.pem se trouve dans la CRL.**
    Décrire la méthode employée.

`openssl x509 -in cyber.gouv.fr.pem -serial -noout`

```
┌──(kali㉿kali)-[~]
└─$ openssl x509 -in cyber.gouv.fr.pem -serial -noout
serial=0C3FA55CC15F1BDC120E51B0D3C5E8B4
```

On cherche avec **grep** le numéro de série dans la CRL **certigna.crl**

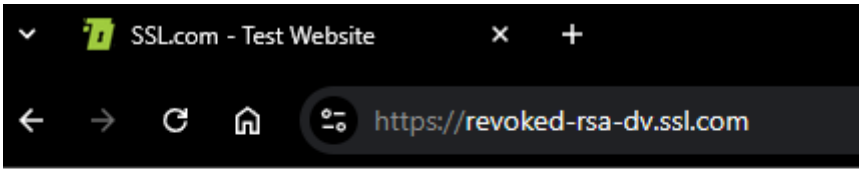
`openssl crl -in certigna.crl -inform DER -text -noout | grep -i "0C3FA55CC15F1BDC120E51B0D3C5E8B4"`

```
┌──(kali㉿kali)-[~]
└─$ openssl crl -in certigna.crl -inform DER -text -noout | grep -i "0C3FA55CC15F1BDC120E51B0D3C5E8B4"
```

Le numéro ne figure pas dans la CRL. Donc le certificat n'est pas révoqué

La révocation

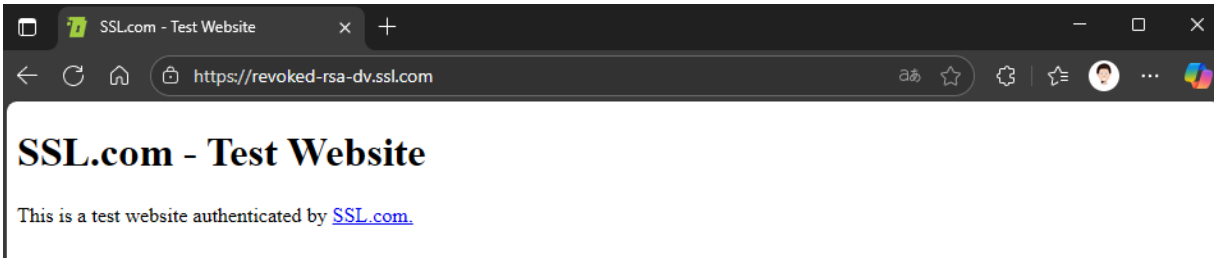
Sur google :



SSL.com - Test Website

This is a test website authenticated by SSL.com.

Sur Microsoft Edge :



Sur Opera GX :



La raison pour laquelle tu vois le site "SSL.com - Test Website" sans aucun avertissement de sécurité indiquant "Connexion non sécurisée — certificat révoqué" est liée à la manière dont la plupart des navigateurs gèrent la vérification de la révocation des certificats. Beaucoup de navigateurs modernes comme Chrome et Edge ne vérifient pas systématiquement en temps réel si un certificat SSL a été révoqué via OCSP ou CRL : ils utilisent plutôt des listes de révocation simplifiées (CRLSet) qui ne couvrent pas tous les certificats révoqués. Résultat : le site peut apparaître comme si tout est normal, même si le certificat est révoqué.

Récupérez le certificat du site https://revoked-rsa-dv.ssl.com/ et l'enregistrer dans le fichier revoked-rsa-dv.ssl.com.pem

```
openssl s_client -connect revoked-rsa-dv.ssl.com:443 -showcerts </dev/null 2>/dev/null | openssl x509 -outform PEM > revoked-rsa-dv.ssl.com.pem
```

17. **De la même manière que tout à l'heure, vérifiez si le numéro de série du certificat se trouve dans la CRL de l'autorité de certification. D'après vos observations, commentez.**

On regarde le .pem pour trouver le numéro de série

```
openssl x509 -in revoked-rsa-dv.ssl.com.pem -serial -noout
```

```
┌──(kali㉿kali)-[~]
└─$ openssl x509 -in revoked-rsa-dv.ssl.com.pem -serial -noout
serial=3898BD93BF32C3FCCBF729E08A920256
```

On regarde le .pem pour trouver l'URL du CRL et le numéro de série

```
openssl x509 -in revoked-rsa-dv.ssl.com.pem -text -noout
```

```
X509v3 CRL Distribution Points:
    Full Name:
      URI:http://crls.ssl.com/SSLcom-SubCA-SSL-RSA-4096-R1.crl
```

```
wget http://crls.ssl.com/SSLcom-SubCA-SSL-RSA-4096-R1.crl -O ssl_com.crl
```

```
┌──(kali㉿kali)-[~]
└─$ wget http://crls.ssl.com/SSLcom-SubCA-SSL-RSA-4096-R1.crl -O ssl_com.crl
--2025-10-24 04:43:04--  http://crls.ssl.com/SSLcom-SubCA-SSL-RSA-4096-R1.crl
Resolving crls.ssl.com (crls.ssl.com)... 143.204.194.39, 143.204.194.94, 143.204.194.124, ...
Connecting to crls.ssl.com (crls.ssl.com)|143.204.194.39|:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 58114 (57K) [application/pkix-crl]
Saving to: 'ssl_com.crl'

ssl_com.crl                 100%[=========================================>]  56.75K  --.-KB/s    in 0.05s

2025-10-24 04:43:04 (1.11 MB/s) - 'ssl_com.crl' saved [58114/58114]
```

```
openssl crl -in ssl_com.crl -inform DER -text -noout | grep -i "3898BD93BF32C3FCCBF729E08A920256"
```

```
┌──(kali㉿kali)-[~]
└─$ openssl crl -in ssl_com.crl -inform DER -text -noout | grep -i " 3898BD93BF32C3FCCBF729E08A920256"
    Serial Number: 3898BD93BF32C3FCCBF729E08A920256
```

On voit bien que le numéro de série du site est enregistré dans la liste des certificats révoqués. Donc, le site utilise un certificat révoqué. La connexion n'est pas sécurisée.

Récupérez l'URL du répondeur OCSP du site https://revoked-rsa-dv.ssl.com/

```
Authority Information Access:
    CA Issuers - URI:http://cert.ssl.com/SSLcom-SubCA-SSL-RSA-4096-R1.cer
    OCSP - URI:http://ocsps.ssl.com
```

```
http://ocsps.ssl.com
```

Récupérez également le certificat de l'autorité de certification du site (seule l'autorité subordonnée est nécessaire, pas la racine). L'enregistrer dans un fichier séparé.

```
wget -O issuer_raw.cer 'http://cert.ssl.com/SSLcom-SubCA-SSL-RSA-4096-R1.cer'
```

```
┌──(kali㉿kali)-[~]
└─$ wget -O issuer_raw.cer 'http://cert.ssl.com/SSLcom-SubCA-SSL-RSA-4096-R1.cer'
--2025-10-24 05:23:46--  http://cert.ssl.com/SSLcom-SubCA-SSL-RSA-4096-R1.cer
Resolving cert.ssl.com (cert.ssl.com)... 16.15.176.147, 16.15.207.77, 16.15.178.144, ...
Connecting to cert.ssl.com (cert.ssl.com)|16.15.176.147|:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1651 (1.6K) [application/pkix-cert]
Saving to: 'issuer_raw.cer'

issuer_raw.cer              100%[=========================================>]   1.61K  --.-KB/s    in 0s

2025-10-24 05:23:46 (132 MB/s) - 'issuer_raw.cer' saved [1651/1651]
```

```
# 3c - convertir/normaliser en PEM (fichier final issuer.pem)

# Si c'est DER -> convertir en PEM ; sinon tenter l'affichage en PEM

if file issuer_raw.cer | grep -qi 'der\|data'; then

  openssl x509 -in issuer_raw.cer -inform DER -out issuer.pem -outform PEM

else

  # si déjà PEM, on copie
```

```
  cp issuer_raw.cer issuer.pem
fi
```

18. **A l'aide de la commande OpenSSL ocsp vérifiez le statut du certificat en ligne de commande avec le protocole OCSP.**
    Indiquez la ligne de commande utilisée et commenter le résultat (indice : vous aurez besoin du certificat du site, de l'autorité, de l'URL du répondeur OCSP de l'autorité. Utilisez également l'option -no_nonce)

```
openssl ocsp \
  -issuer issuer.pem \
  -cert revoked-rsa-dv.ssl.com.pem \
  -url http://ocsps.ssl.com \
  -no_nonce
```

```
┌──(kali㉿kali)-[~]
└─$ openssl ocsp \
  -issuer issuer.pem \
  -cert revoked-rsa-dv.ssl.com.pem \
  -url http://ocsps.ssl.com \
  -no_nonce
Response verify OK
revoked-rsa-dv.ssl.com.pem: revoked
        This Update: Oct 24 09:31:14 2025 GMT
        Next Update: Oct 31 09:31:13 2025 GMT
        Revocation Time: Jun  9 15:07:39 2025 GMT
```

Récupérez les certificats des sites https://google.com et https://youtube.com

```
openssl s_client -connect google.com:443 -showcerts </dev/null
2>/dev/null | openssl x509 -outform PEM > google.pem
openssl s_client -connect youtube.com:443 -showcerts </dev/null
2>/dev/null | openssl x509 -outform PEM > youtube.pem
```

19. **Affichez leur numéro de série respectif.**
    Commentez le résultat. Expliquez cet état de fait

```
openssl x509 -in google.pem -serial -noout
```

```
┌──(kali㉿kali)-[~]
└─$ openssl x509 -in google.pem -serial -noout
serial=96728C1FF77BDFB90ACDDEFE41E0AF8A
```

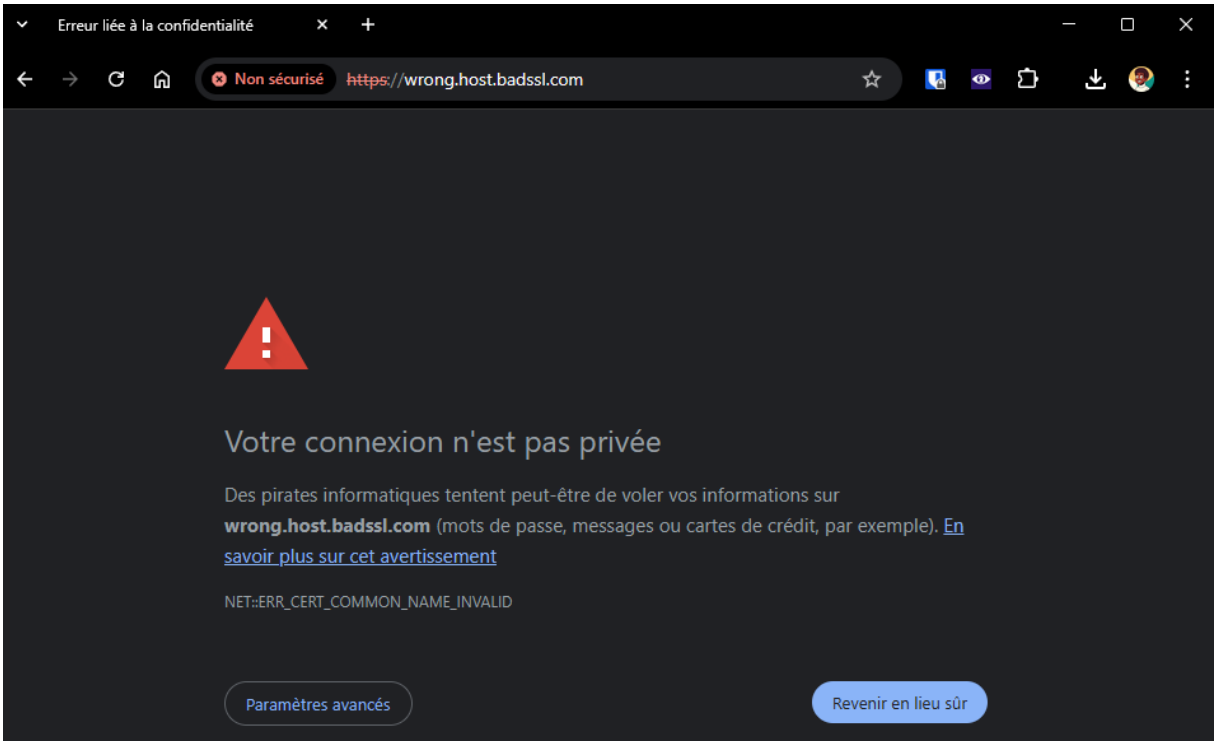
```
openssl x509 -in youtube.pem -serial -noout
```

```
┌──(kali㉿kali)-[~]
└─$ openssl x509 -in youtube.pem -serial -noout
serial=109B3DC015FBA651127CC5D3A9FA684D
```

Les deux certificats ont souvent le même émetteur (Google Trust Services). Les numéros de série sont différents, car chaque certificat serveur est unique.

Se rendre sur https://wrong.host.badssl.com/

20. **Qu'affiche le navigateur ?**
    Est-ce cohérent ? Argumenter malgré le fait que le certificat soit d'un type particulier.
    (indice : https://www.rfc-editor.org/rfc/rfc6125)



Le CN/SAN du certificat ne correspond pas au domaine demandé. Selon la RFC 6125, le nom dans le certificat doit correspondre exactement à l'hôte accédé.

Récupérer les 2 fichiers de certificats (isrg-1.crt et isrg-2.crt)

Pour récupérer la chaîne de certificats depuis `https://wrong.host.badssl.com/`, extraire chaque certificat en fichiers séparés, identifier lesquels sont isrg-1 et isrg-2, et les renommer proprement.

Exécute ces commandes dans l'ordre :

1. **Récupérer la chaîne complète (stdout) dans un fichier**

```
openssl s_client -connect wrong.host.badssl.com:443 -servername wrong.host.badssl.com -showcerts </dev/null 2>/dev/null > chain.pem
```

2. **Séparer chain.pem en plusieurs fichiers cert1.pem, cert2.pem, ...**

```
awk '/-----BEGIN CERTIFICATE-----/{i++} {print > "cert" i
".pem"}' chain.pem
```

3. **Lister les certificats extraits et afficher leur Subject / Issuer (pour identifier lesquels sont isrg-1 / isrg-2)**

```
for f in cert*.pem; do
  echo "==== $f ====";
  openssl x509 -in "$f" -noout -subject -issuer -serial | sed
's/^/  /';
done
```

```
┌──(kali㉿kali)-[~]
└─$ for f in cert*.pem; do
  echo "==== $f ====";
  openssl x509 -in "$f" -noout -subject -issuer -serial | sed 's/^/  /';
done

==== cert1.pem ====
  subject=CN=*.badssl.com
  issuer=C=US, O=Let's Encrypt, CN=R12
  serial=06BF80D445C74FCD3CE2B83DB6B299C8CA4F
==== cert2.pem ====
  subject=C=US, O=Let's Encrypt, CN=R12
  issuer=C=US, O=Internet Security Research Group, CN=ISRG Root X1
  serial=C212324B70A9B49171DC40F7E285263C
==== cert.pem ====
Could not find certificate from cert.pem
```

5. **Renommer les fichiers identifiés en isrg-1.crt et isrg-2.crt**

Supposons que cert1.pem est isrg-1 et cert2.pem est isrg-2 (vérifie l'étape 3 pour confirmer) :

```
mv cert1.pem isrg-1.crt
mv cert2.pem isrg-2.crt
```

21. Les afficher, les examiner et les commenter

```
openssl x509 -in isrg-1.crt -text -noout
```

```
┌──(kali㉿kali)-[~]
└─$ openssl x509 -in isrg-1.crt -text -noout
Certificate:
    Data:
        Version: 3 (0×2)
        Serial Number:
            06:bf:80:d4:45:c7:4f:cd:3c:e2:b8:3d:b6:b2:99:c8:ca:4f
        Signature Algorithm: sha256WithRSAEncryption
        Issuer: C=US, O=Let's Encrypt, CN=R12
        Validity
            Not Before: Sep 16 20:02:48 2025 GMT
            Not After : Dec 15 20:02:47 2025 GMT
        Subject: CN=*.badssl.com
        Subject Public Key Info:
            Public Key Algorithm: rsaEncryption
                Public-Key: (2048 bit)
                Modulus:
                    00:98:a4:14:13:87:a1:50:71:9b:a6:73:72:d7:df:
                    e5:38:e9:34:69:0e:77:3c:e1:5d:1b:ba:40:d7:27:
                    37:28:95:e3:2a:22:73:96:bc:8a:19:b1:08:97:69:
                    88:08:5a:b6:56:11:36:9f:14:41:a9:4b:98:5c:df:
                    f4:4c:e1:87:73:fb:69:2e:41:0f:8b:24:01:d3:ed:
                    b9:36:65:ce:da:1e:8f:fb:42:18:c6:8c:bf:e3:04:
                    6b:ac:26:a4:54:ce:8f:f9:9f:c6:dd:89:7b:06:9a:
                    1b:0c:0a:f4:a6:f8:bd:9b:1b:58:ba:24:1f:00:24:
                    4e:5a:80:58:84:c6:78:85:60:76:54:0b:db:bc:8e:
                    18:45:89:6f:a7:3b:0b:c8:c9:72:1a:ef:95:2b:46:
                    3a:57:68:5f:0b:a8:82:98:8a:95:22:82:ae:21:06:
                    d1:04:d8:bb:33:ef:78:f2:f3:4d:ea:74:61:c9:54:
                    31:0e:f9:90:a8:92:cf:b0:1f:07:c4:59:e1:38:e4:
                    4d:60:eb:8f:f8:89:a7:2d:42:a2:b5:82:dd:c6:eb:
                    eb:62:ed:f6:96:7e:5b:20:84:0f:c5:51:00:6d:03:
                    33:a7:8b:24:cf:e5:7d:0b:fc:ca:7a:45:76:98:f5:
                    8e:ed:09:cb:71:fc:ab:6b:7f:79:51:87:b3:04:f4:
                    31:51
                Exponent: 65537 (0×10001)
        X509v3 extensions:
            X509v3 Key Usage: critical
                Digital Signature, Key Encipherment
            X509v3 Extended Key Usage:
                TLS Web Server Authentication, TLS Web Client Authentication
            X509v3 Basic Constraints: critical
                CA:FALSE
            X509v3 Subject Key Identifier:
                BA:50:A8:AF:64:D0:B5:3B:9A:FB:A5:A9:E9:E7:0B:B8:35:9B:DD:77
            X509v3 Authority Key Identifier:
                00:B5:29:F2:2D:8E:6F:31:E8:9B:4C:AD:78:3E:FA:DC:E9:0C:D1:D2
            Authority Information Access:
                CA Issuers - URI:http://r12.i.lencr.org/
            X509v3 Subject Alternative Name:
                DNS:*.badssl.com, DNS:badssl.com
```

openssl x509 -in isrg-2.crt -text -noout

```
└─$ openssl x509 -in isrg-2.crt -text -noout
Certificate:
    Data:
        Version: 3 (0x2)
        Serial Number:
            c2:12:32:4b:70:a9:b4:91:71:dc:40:f7:e2:85:26:3c
        Signature Algorithm: sha256WithRSAEncryption
        Issuer: C=US, O=Internet Security Research Group, CN=ISRG Root X1
        Validity
            Not Before: Mar 13 00:00:00 2024 GMT
            Not After : Mar 12 23:59:59 2027 GMT
        Subject: C=US, O=Let's Encrypt, CN=R12
        Subject Public Key Info:
            Public Key Algorithm: rsaEncryption
                Public-Key: (2048 bit)
                Modulus:
                    00:da:98:28:74:ad:be:94:fe:3b:e0:1e:e2:e5:4b:
                    75:ab:2c:12:7f:ed:a7:03:32:7e:36:97:ec:e8:31:
                    8f:a5:13:8d:0b:99:2e:1e:cd:01:51:3d:4c:e5:28:
                    6e:09:55:31:aa:a5:22:5d:72:f4:2d:07:c2:4d:40:
                    3c:df:01:23:b9:78:37:f5:1a:65:32:34:e6:86:71:
                    9d:04:ef:84:08:5b:bd:02:1a:99:eb:a6:01:00:9a:
                    73:90:6d:8f:a2:07:a0:d0:97:d3:da:45:61:81:35:
                    3d:14:f9:c4:c0:5f:6a:dc:0b:96:1a:b0:9f:e3:2a:
                    ea:bd:2a:d6:98:c7:9b:71:ab:3b:74:0f:3c:db:b2:
                    60:be:5a:4b:4e:18:e9:db:2a:73:5c:89:61:65:9e:
                    fe:ed:3c:a6:cb:4e:6f:e4:9e:f9:00:46:b3:ff:19:
                    4d:2a:63:b3:8e:66:c6:18:85:70:c7:50:65:6f:3b:
                    74:e5:48:83:0f:08:58:5d:2d:23:9d:5e:a3:fe:e8:
                    db:00:a1:d2:f4:e3:19:4d:f2:ee:7a:f6:27:9e:e5:
                    cd:9c:2d:a2:f2:7f:9c:17:ad:ef:13:37:39:d1:b4:
                    c8:2c:41:d6:86:c0:e9:ec:21:f8:59:1b:7f:b9:3a:
                    7c:9f:5c:01:9d:62:04:c2:28:bd:0a:ad:3c:ca:10:
                    ec:1b
                Exponent: 65537 (0x10001)
        X509v3 extensions:
            X509v3 Key Usage: critical
                Digital Signature, Certificate Sign, CRL Sign
            X509v3 Extended Key Usage:
                TLS Web Client Authentication, TLS Web Server Authentication
            X509v3 Basic Constraints: critical
                CA:TRUE, pathlen:0
            X509v3 Subject Key Identifier:
                00:B5:29:F2:2D:8E:6F:31:E8:9B:4C:AD:78:3E:FA:DC:E9:0C:D1:D2
            X509v3 Authority Key Identifier:
                79:B4:59:E6:7B:B6:E5:E4:01:73:80:08:88:C8:1A:58:F6:E9:9B:6E
            Authority Information Access:
                CA Issuers - URI:http://x1.i.lencr.org/
            X509v3 Certificate Policies:
                Policy: 2.23.140.1.2.1
            X509v3 CRL Distribution Points:
                Full Name:
```

isrg-1.crt — Leaf certificate (serveur)

- **Subject** : CN=*.badssl.com → **Wildcard** : couvre badssl.com + tous les sous-domaines *.badssl.com.
- **Issuer** : C=US, O=Let's Encrypt, CN=R12 → émis par l'intermédiaire *R12*.

- **Validité** : Not Before: Sep 16 20:02:48 2025 → Not After: Dec 15 20:02:47 2025 → **valide aujourd'hui (24 Oct 2025)**.
- **Serial** : hex long 06:bf:80:... (identifiant unique).
- **Algorithme de signature** : sha256WithRSAEncryption.
- **Taille clé publique** : **RSA 2048 bits** (standard, sécurisé pour TLS).
- **Key Usage** : Digital Signature, Key Encipherment (usage typique d'un certificat serveur).
- **Extended Key Usage** : TLS Web Server Authentication, TLS Web Client Authentication (ok pour HTTPS).
- **Basic Constraints** : CA:FALSE → **ce n'est pas une CA** (ne peut pas signer d'autres certs).
- **SAN (SubjectAltName)** : DNS:*.badssl.com, DNS:badssl.com → couvre le wildcard et le nom nu.
- **AIA (Authority Information Access)** : CA Issuers - URI:http://r12.i.lencr.org/ → URL pour récupérer l'intermédiaire.
- **CRL Distribution Point** : URI:http://r12.c.lencr.org/80.crl → CRL pour ce certificat/intermédiaire.
- **CT Precertificate SCTs** : présents → certificate transparency (log public), normal pour les certs publics.

Interprétation / commentaires

- C'est **un certificat de serveur standard** (leaf) émis par l'intermédiaire R12 de Let's Encrypt.
- Le wildcard est pratique pour tester plusieurs sous-domaines (badssl fournit ces tests).
- Les usages et extensions sont corrects : il permet la négociation TLS, mais **n'autorise pas de signer d'autres certificats**.
- Les champs AIA/CRL permettent la récupération automatique d'intermédiaire / CRL si tu veux vérifier révocation.

isrg-2.crt — Intermediate CA (Let's Encrypt R12)

- **Subject** : C=US, O=Let's Encrypt, CN=R12 → c'est l'intermédiaire R12 (le même que l'issuer du leaf).

- **Issuer** : C=US, O=Internet Security Research Group, CN=ISRG Root X1 → signé par la **racine ISRG Root X1**.
- **Validité** : Not Before: Mar 13 2024 → Not After: Mar 12 2027 → **valide**.
- **Key Usage** : Digital Signature, Certificate Sign, CRL Sign → **peut signer des certificats** et des CRL.
- **Basic Constraints** : CA:TRUE, pathlen:0 → **intermédiaire CA**; pathlen:0 signifie qu'il **ne peut créer que des certs finaux ou sous-CAs avec pathlen ≤ 0** — en pratique R12 ne peut pas émettre d'autres CAs intermédiaires (limite de profondeur).
- **Subject Key Identifier / Authority Key Identifier** : permettent de lier la chaîne (vérifier la correspondance avec l'issuer des autres certs).
- **AIA** : CA Issuers - URI:http://x1.i.lencr.org/ → URL pour récupérer l'ISSUER (racine ou chaîne).
- **CRL DP** : URI:http://x1.c.lencr.org/ → CRL pour cet intermédiaire.
- **Taille clé** : **2048 bits**, algorithme RSA, signature SHA256.

Interprétation / commentaires

- **C'est l'intermédiaire qui signe les certificats Let's Encrypt R12**. Il est **autorisé** à signer des certificats serveurs (KeyCertSign) et des CRL.
- pathlen:0 est une bonne pratique : l'intermédiaire peut émettre des certs finaux mais **ne peut pas déléguer** davantage la capacité de créer des CAs (empêche création de chaînes trop longues).
- Le certificat est correctement configuré pour jouer le rôle d'intermédiaire dans la chaîne de confiance.
- Vérifier l'**Issuer** (ISRG Root X1) → si tu veux valider la chaîne, tu dois posséder la racine ISRG Root X1 en tant que trust anchor.